# SEGMENT-8



# PHASES IN SELECTION

- 2 Phases in Selection:

- HARDWARE Selection
- SOFTWARE Selection

# HARDWARE SELECTION CRITERIA

- Hardware must support current software as well as software planned for procurement over the next planning interval [*year, 18 months, three years*]
- Hardware must be compatible with existing or planned networks
- Hardware must be upgradeable and expandable to meet the needs of the next planning interval

# CONTINUE

- Hardware warranties must be of an appropriate length
- Hardware maintenance must be performed by [*local/remote vendor, in-house personnel*]
- Whenever feasible, hardware standards will dictate procurement of like brands and configurations to simplify installation and support
- Routine assessments of installed infrastructure will feed an upgrade/replace decision process

# SOFTWARE SELECTION CRITERIA

- Software must be compatible with current and future hardware over the next planning interval
- Software maintenance and warranties must be of appropriate length and cost
- Software help desk must be maintained by [*vendor, third party, in-house personnel*]

# CONTINUE

- Software must be standardized throughout the business to improve purchasing power, simplify training, and facilitate support
- 
- Software must comply with current standards set by technology leadership
- Software must support and enhance business goals

# OTHER TOPICS

- **What is Security?**
- **Security Issues**
- **Security Threats**
- **Security Goals**
- **Vulnerabilities**
- **Computer Criminals**
- **Method of Defense**
- **System Access Controls**

# WHAT IS SECURITY?

- **Prevention:** take measures that prevent your assets from being damaged
- **Detection:** take measures so that you can detect when, how, and by whom an asset has been damaged
- **Reaction:** take measures so that you can recover your assets or to recover from a damage to your assets

# SECURITY ISSUES

- **Exposure:** A single instance when the system is open to damage
- **Vulnerability:** Weakness in the system that might be exploited to cause loss or harm
- **Threats:** Objects, persons, or other entities that represents a potential danger to the system
- **Control:** Protective measure – action, procedure or techniques to reduce vulnerability

# SECURITY ISSUES EXAMPLE

**House**

- **Vulnerability:** poor home security (no proper door lock, no alarm system, etc)
- **Exposure:** let the door / window open
- **Threats:** Burglar / thieves
- **Control:** deploy alarm system, more padlock

**Computer System**

- **Vulnerability:** Poor system protection (no firewall, no anti-virus, etc)
- **Exposure:** unauthorized disclosure of data (i.e. Write password on a piece of paper)
- **Threats:** Hackers, virus
- **Control:** Install firewall, install anti-virus, software patch

# SECURITY THREATS

- Threats are viewed as types of attacks on normal services
- What is normal service?

# SECURITY THREATS

- **System:** Collection of hardware, software, storage media, data and people that organization uses to perform computing task
- **Asset:** Organizational resource that is being protected
- Four kinds of threats: **interruption**, **interception**, **modification**, **fabrication**

# INTERRUPTION

- Asset of the system becomes lost/unavailable/unusable
- Example: destruction of hardware, software or data; interference with a communications channel, overloading a shared resource

# INTERCEPTION

- Unauthorized access to an asset of the system
- Example : Eavesdropping, wiretapping, masquerading, break-ins, illicit data copying

# MODIFICATION

- Tampering the asset of the system by unauthorized party
- Example : change the value of database, alter programs to perform additional computation

# FABRICATION

- Skill full modifications of the system that could be virtually indistinguishable(হুবহু একই রকম) from real thing
- Example : Intruder might insert spurious transaction to a network communication system

# SECURITY GOALS

- Prevent the vulnerability from being exploited
- Maintaining three characteristic: Confidentiality, integrity, availability
- **Confidentiality:** assets are accessible only by authorised party
- **Integrity:** assets can be modified only by authorised party or only in authorised ways
- **Availability:** assets are accessible to authorised party

# VULNERABILITIES

- In computing, vulnerabilities apply to all three broad categories of system resources namely:
  - Hardware
  - Software
  - Data

# HARDWARE VULNERABILITIES

- More visible than software largely because it is composed of physical objects
- Attacks can be done by adding devices, changing them, removing them, intercepting the traffic to them or flooding them with traffic until they no longer function.
- Subject to other physical attacks such as burned, drenched with water, etc

# SOFTWARE VULNERABILITIES

- Software can be replaced, changed, or destroyed maliciously, modified, deleted or misplaced accidentally.
- These vulnerabilities are usually exploited in software attacks.
- Example of attacks include deletion, modification, virus, Trojan horse, trapdoor, information leaks, theft.

# DATA VULNERABILITIES

- Data items have greater public value than hardware and software because more people know how to use or interpret data.
- Out of context pieces of data has no intrinsic value for example, the value “42” has no meaning unless you know what the number represents

# DATA VULNERABILITIES

- The value of data over time is less predictable and not consistent.
- Initially data may be valued highly and their value may decline after a certain period of time.
- As such they should be granted protection consistent with their value and protected only until they lose their value.

# COMPUTER SECURITY GOALS AND DATA

- Confidentiality
  - Prevents the unauthorised disclosure of data item
- Integrity
  - Prevents unauthorized modification
- Availability
  - Prevents the denial of authorized access

# OTHER EXPOSED THREATS

- Networks
  - Specialised collections of hardware, software and data. Each network node is itself a computing system ; as such it experiences all the normal security problems.
- Access
  - Steal computing time for general purpose computing
  - Malicious Access to computing system
  - Unauthorised access may deny service to legitimate users
- People
  - Dependency on one person to maintain a program

# COMPUTER CRIMINALS

- Amateurs
  - Committed most of the computer crimes reported to date
  - They observed a weakness in a security system that allows them to access cash or other valuables.
  - Usually ordinary computer users who while doing their jobs, discover they have access to something valuable.

# COMPUTER CRIMINALS

- Crackers or Malicious Hackers
  - System crackers often attempt to access computing facilities for which they are not authorised.
- Career Criminals
  - Understands the target of computer crime
- Terrorists
  - Use computers as
    - Targets of attack, propaganda vehicles. Methods of attacks.

# 4. METHOD OF DEFENSE

- Controls or countermeasures that attempt to prevent a computing system vulnerability and preserving confidentiality, integrity and availability
- **Encryption**
- **Software Controls**
- **Hardware Controls**
- **Policies**

# ENCRYPTION

- Transforming data (cleartext) so that it is unintelligible to the outside observer
- Most powerful tool
- Provides confidentiality and integrity
- Availability?

# SOFTWARE / PROGRAM CONTROLS

- Internal program controls
- Operating system and network system controls
- Independent control programs
- Development controls

# HARDWARE CONTROLS & POLICIES

- **Hardware Controls:** Using hardware devices in providing computer security (i.e..: Smart card, locks, firewalls, intrusion detection system, etc.)

- **Policies:** Agreed upon procedures through legal and ethical control (i.e..: Frequent change of password, training, cyber law, etc.)

# WHAT MAKES A SYSTEM SECURE?

- Protect asset from all security treats
- Four primary methods of system protection:
  - System access control
  - Data access control
  - System and security administration
    - Offline procedures that make or break a secure system (i.e.. training, security alert and bulletin, etc)
  - System design
    - Take advantage of h/ware and s/ware security characteristics (i.e.. system architecture that able to segment memory)

# SYSTEM ACCESS CONTROL

- Identification and Authentication:
  - Something you know (i.e..: password)
  - Something you have (i.e..: keys, tokens, smart cards, ..)
  - Something you are (fingerprint, handprint, retina pattern …)
- System audit and log: to keep track of what you are doing in a system
- Protecting login and password entry:
  - Limited attempts
  - Limited time periods
  - Password aging and expiration
- Password Storage protection: Encryption, access controls

# DATA ACCESS CONTROL

- Monitor who can access what data and for what purpose
- Discretionary access control: you decide how to protect your asset and type of access allowed
  - Access Control Matrix
  - Capabilities
  - Access Control List (ACL)
- Mandatory access control: The system protect your asset

# ACCESS CONTROL MATRIX

- Object: resources being protected
- Subject: Entities attempting to access the object
- 2D description of data access right

| | file1 | file2 | file3 |
|---|---|---|---|
| Ross | - | {read} | {read, write} |
| Monica | {read,write} | {exec} | {exec,read,write} |

# CAPABILITIES AND ACL

- **Capabilities:** Focus on the subject (Rows of the access control matrix)

| | | |
|---|---|---|
| Ross | file2: {read} | file3: {read. write} |

- **ACL:** Focus on the object (columns of the access control matrix)

| | | |
|---|---|---|
| file3 | Ross: {read,write} | Monica: {exec,read,write} |

# MANDATORY ACCESS CONTROL

- Assign sensitivity level to all subjects and objects
- Sensitivity has two parts; classification and set of categories

- Example: SECRET [ FIT, FOE, FCM ]
- **Classification:** hierarchical (i.e..: top secret, secret, confidential, unclassified)
- **Categories:** set of clearance / authorization required
- Access decision is based on the following:
  - ✓ Label of the subject (i.e.: user hierarchy and clearance)
  - ✓ Label of the object (i.e.: file sensitivity)
  - ✓ Access request: READ / WRITE